



1) ZERO-DAY (OU "JOUR ZÉRO")

Une attaque est qualifiée de "Zero-Day" lorsque l'exploit (le code ou la méthode utilisé par l'attaquant) est découvert et utilisé pour compromettre un système avant que l'éditeur du logiciel (le développeur) n'ait eu connaissance de la vulnérabilité et, par conséquent, n'ait eu le temps de créer et de diffuser un correctif (un patch).

Le nom fait directement référence à la durée dont dispose l'éditeur pour réagir au moment où l'attaque se produit : zéro jour.

LES ÉLÉMENTS CLÉS DU CONTEXTE :-

- **Vulnérabilité Inconnue de l'Éditeur** : La faille de sécurité existe dans le logiciel, mais elle est totalement inconnue de l'équipe de développement ou du fournisseur au moment où l'attaque est lancée.
- **Exploitation Active** : Un acteur malveillant (pirate, groupe criminel, État) découvre la faille et développe un code malveillant (l'exploit) pour l'utiliser activement contre des cibles.
- **Absence de Protection** : Puisque la vulnérabilité est inconnue, il n'existe aucune parade de sécurité connue (pas de signature antivirus, pas de mise à jour, pas de correctif) pour la bloquer.
- **Fenêtre de Risque Maximum** : L'attaque Zero-Day se produit pendant la période critique qui s'étend de la découverte et de l'exploitation de la faille par les attaquants jusqu'au moment où l'éditeur publie son correctif (le "patch").

Dès qu'un correctif est publié, la vulnérabilité ou l'attaque ne sont plus techniquement appelées "Zero-Day", mais simplement une "vulnérabilité connue" (ou "N-Day") pour laquelle une solution existe.



2) COMMENT SE PROTÉGER DES ATTAQUES DOS (DÉNI DE SERVICE)

Une attaque DoS vise à rendre un service, un site web ou un réseau indisponible pour ses utilisateurs légitimes en le submergeant de requêtes ou de trafic. Pensez à une petite boutique qui serait soudainement inondée par des milliers de personnes, empêchant les vrais clients d'entrer.

TECHNOLOGIES ACTUELLES DE PROTECTION:-

1. Pare-feux (Firewalls): Filtrent le trafic réseau.
2. Systèmes de Détection et de Prévention d'Intrusion (IDS/IPS): Surveillent le trafic pour identifier et bloquer les activités malveillantes.
3. Services de Nettoyage de Trafic (Scrubbing Centers): Redirigent le trafic vers des centres spécialisés qui filtrent les requêtes malveillantes avant de les renvoyer au serveur.
4. Content Delivery Networks (CDNs): Distribuent le trafic sur de multiples serveurs, ce qui rend difficile de saturer un seul point.
5. Limitation de Débit (Rate Limiting): Restreint le nombre de requêtes qu'une adresse IP peut faire dans un certain laps de temps.

SERVICES DE NETTOYAGE DE TRAFIC (SCRUBBING CENTERS) :-

Les services de nettoyage de trafic sont une défense très efficace contre les attaques DoS, en particulier les attaques DDoS (Déni de Service Distribué), qui utilisent plusieurs sources pour submerger la cible.

Quand une attaque est détectée, le trafic destiné à la cible est dévié vers ces centres. Ces centres disposent d'une énorme capacité de bande passante et de puissants outils d'analyse qui peuvent distinguer le trafic légitime des requêtes malveillantes ou du "bruit" de l'attaque. Une fois le trafic "nettoyé", il est renvoyé vers la destination originale, permettant au service de rester disponible pour ses utilisateurs légitimes. C'est un peu comme un barrage qui dévierait une inondation pour protéger la ville en aval.

3) LE MODÈLE AAA : AUTHENTICATION, AUTORISATION, ACCOUNTING

Le terme AAA est l'acronyme de trois services de sécurité fondamentaux : Authentification, Autorisation, et Comptabilité (souvent désignée par le terme anglais *Accounting*).

1. AUTHENTICATION (AUTHENTICATION) :-

- **Rôle : Qui êtes-vous ?**
 - C'est la première étape du modèle. Elle consiste à **vérifier l'identité** d'un utilisateur, d'un processus ou d'un appareil qui tente d'accéder à une ressource.
 - **Exemples** : Entrer un nom d'utilisateur et un mot de passe ; utiliser une authentification multifacteur (MFA) ; présenter un certificat numérique.
 - **Objectif Simplifié** : Prouver que vous êtes bien celui que vous prétendez être.
-

2. AUTORISATION (AUTHORIZATION) :-

- **Rôle : Qu'avez-vous le droit de faire ?**
 - Une fois que l'utilisateur est authentifié, l'autorisation détermine quelles actions cet utilisateur est autorisé à effectuer et quelles ressources il peut accéder.
 - **Exemples** : Un utilisateur est autorisé à *lire* un fichier, mais pas à le *modifier* ; un administrateur peut accéder à tous les serveurs, un utilisateur standard seulement à sa boîte mail.
 - **Objectif Simplifié** : Définir les permissions et les privilèges spécifiques accordés à l'identité prouvée.
-

3. COMPTABILITÉ (ACCOUNTING) :-

- **Rôle : Qu'avez-vous fait ?**
- La comptabilité est le processus de **suivi, d'enregistrement** et de journalisation des actions effectuées par l'utilisateur une fois qu'il a été authentifié et autorisé.
- **Exemples** : Enregistrer l'heure de connexion et de déconnexion, les fichiers accédés, les modifications apportées aux systèmes, les commandes exécutées.
- **Objectif Simplifié** : Fournir une piste d'audit pour la détection d'anomalies, la facturation des services (si applicable) et la conformité légale.